

Information Security

Organization NAME: "Alibaba"

Asset Inventory:-

Asset ID	Asset Name	Type
A ₁	Customer Database	Data
A ₂	Tmall Transaction Platform	Software
A ₃	Alipay Payment Gateway	Software
A ₄	Cainiao Logistics Network	Physical/Software
A ₅	Alibaba Cloud Infrastructure	Infrastructure

Vulnerabilities:-

Assets ID	Vulnerabilities
A ₁	Weak API authentication, Unpatched DB, Insider Access abuse, no encryption at rest.
A ₂	Single point of failure, legacy code modules.
A ₃	Third-party bank dependency, outdated SSL/TLS, regulatory grey areas in multiple countries.
A ₄	Single-region warehouse, manual inventory tracking, weak physical access control
A ₅	Misconfigured cloud storage, no backups, over-privileged roles, shared tenancy risks.

3) → Formulas:-

Basic Risk Formula : $Risk = Likelihood \times Impact$

Internal & External Attack formula:

Total Risk = Risk (Internal) + Risk (External)

∴ Risk (Internal) = Likelihood (Internal) + Impact (Internal)

∴ Risk (External) = Likelihood (External) + Impact (External).

Likelihood scale:

1 = Rare (Once in 5+ years)

2 = Unlikely (Once in 2-5 years)

3 = Possible (Once in a year)

4 = Likely (2-4 times a year)

5 = Almost certain (monthly).

Impact Scale:-

1 = Negligible

2 = Minor

3 = Moderate

4 = Major

5 = Severe

Risk Level:-

1-6 = Low

7-14 = Medium

15-20 = High

21-25 = Critical

4 $\Rightarrow$ Calculation:-

Asset ID	Attack Type	Likelihood	Impact	Risk	Risk level
A1	Internal (Rogue Employee)	3	5	15	High
	External (Hacker/Ransomware)	4	5	20	High
A2	Int (Back code deploy)	2	5	10	Medium
	Ext (DDoS Attack)	2	5	15	High
A3	Int (Payment logic Bug)	2	5	10	Medium
	Ext (Fraud Ring/API hack)	3	4	12	Medium
A4	Int (Warehouse theft)	3	3	9	Medium
	Ext (Cyber Attack)	2	4	8	Medium
A5	Int (Misconfiguration)	4	5	20	High
	Ext (State-Sponsored Attack)	2	5	10	Medium

5.7 Total Risk Per Asset:-

Asset	I-Risk	E-Risk	Total Risk	Priority
A1	15	20	35	1
A2	20	10	30	2
A3	10	15	25	3
A4	10	12	22	4
A5	9	8	17	5

6. Risk-Mitigation Technique

$$\text{Residual Risk} = \text{Initial Risk} - (\text{Mitigation Effectiveness} \times \text{Initial Risk})$$

Where $\Rightarrow$ Mitigation Effectiveness = 0 to 1

$\Rightarrow$ Target: Residual Risk ≤ 5 for High/Critical Risks

Asset	Attack Type	Initial Risk	M-Technique	Effectiveness	Residual Risk
A1	Internal (15)	15	RBAC + Audit logs + Mandatory 2-week vacations	0.7	4.5
A1	External (20)	20	Encryption at rest + WAF + 24/7 SOC + Backups	0.8	4.0
A1	Internal (20)	20	Infrastructure as code + peer review + automated remediation	0.8	4.0
A5	External (10)	10	Multi-region deployment + DDoS Protection + CSPM tools	0.6	4.0

A ₂	External (15)	15	load testing + auto scaling + chaos Engineering	0.7	4.5
A ₂	Internal (10)	10	CI/CD pipeline security + canary deployments + Rollback plan	0.6	4.0
A ₃	External (12)	12	ML Fraud detection + redundant payment processors + geo-blocking	0.65	4.2
A ₃	Internal (10)	10	Unit tests + automated reconciliation + staging environment	0.65	3.5
A ₄	External (8)	8	API encryption + access tokens + rate limiting	0.5	4.0
A ₄	Internal (9)	9	CCTV + RFID tracking + Random Inventory audits	0.55	4.05

7.7 Risk Register

ID	Asset	Type	Likelihood	Impact	Risk	Residual Risk
R01	A1	External	4	5	20	4.0
R02	A1	Internal	3	5	15	4.5
R03	A5	Internal	4	5	20	4.0
R04	A2	External	3	5	15	4.5
R05	A5	Internal	2	5	10	4.0
R06	A3	External	3	4	12	4.2
R07	A2	Internal	2	5	10	4.0
R08	A3	Internal	2	5	10	3.5
R09	A4	Internal	3	3	9	4.05
R10	A4	External	2	4	8	4.0

8 ⇒ Internal vs External Risk:-

Asset	Internal Risk	External Risk	Higher
A1	15	20	External
A5	20	10	Internal
A2	10	15	External
A3	10	12	External
A4	9	8	Internal.